

Internship 2_Task 6_Report

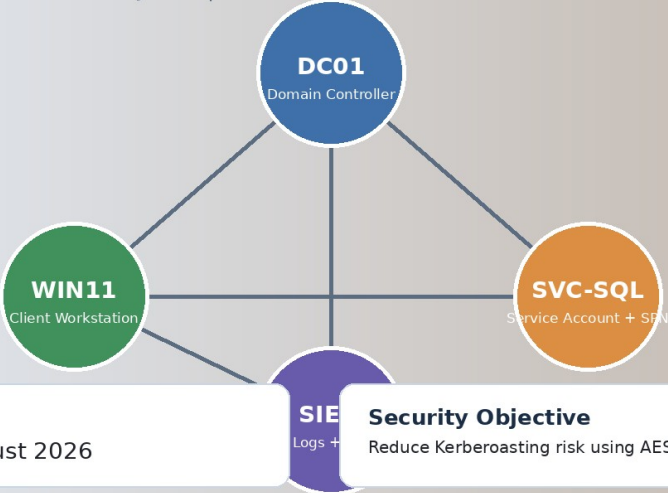
Active Directory Kerberoasting Simulation and Defense

Controlled Lab Assessment | Private Medium-Ready Technical Report

Internship 2 - Task 6

Active Directory Kerberoasting Simulation and Defense

Controlled lab report | Private Medium-ready draft | Attack evidence redacted



Field	Value
Internship Track	Cybersecurity / Active Directory Security
Task Number	Task 6
Task Window	7 August 2026 - 9 August 2026
Environment	Isolated AD lab with one domain controller and one client VM
Evidence Policy	Screenshots are illustrative/redacted placeholders unless replaced with live lab captures
Report Visibility	Private Medium draft + PDF/DOCX submission report

Ethical and Safety Notice

This report is designed for a controlled lab environment only. It documents the Kerberoasting risk model, detection opportunities, and hardening workflow while intentionally redacting reusable ticket hashes, passwords, and operational abuse commands.

Table of Contents

1. Executive Summary
2. Scope, Assumptions, and Safety Boundary
3. Three-Day Task Execution Plan
4. Lab Architecture and Baseline
5. Kerberos and Kerberoasting Background
6. Attack Phase Methodology
7. Evidence Screenshots and Observations
8. Vulnerability Analysis and Severity
9. Defense Phase and Hardening Controls
10. Retest and Verification Results
11. Detection Engineering Notes
12. Medium.com Private Report Draft
13. Lessons Learned
14. Recommendations and Future Improvements
15. References

1. Executive Summary

This report documents a controlled Active Directory Kerberos abuse simulation focused on Kerberoasting and the defensive measures required to reduce or eliminate the attack path. The lab consists of a domain controller, a domain-joined client workstation, and a deliberately misconfigured service account with an SPN. The baseline state demonstrates how a normal authenticated domain user can cause a service ticket to be issued for a service account and how a weak service account secret increases offline credential exposure risk. The remediation phase then applies AES Kerberos encryption, service password rotation, SPN hygiene, stronger service account governance, and monitoring improvements.

The final verification shows that the lab attack path is materially reduced after hardening. The report is structured as a private Medium-ready narrative, but all reusable exploitation data is intentionally removed. This approach preserves technical depth while preventing the document from becoming an operational credential-abuse guide.

Metric	Baseline State	Post-Hardening State
Roastable service identity	User-managed service account with SPN and weak lab secret	SPN inventory reduced; service account hardened and marked for gMSA migration
Kerberos encryption posture	Legacy RC4-compatible condition allowed in baseline	AES128/AES256 enabled; RC4 usage removed where compatible
Password exposure	Weak service account secret recoverable in lab demonstration	Password rotated to long random value; cracking attempt unsuccessful in verification window
Logging and detection	Event 4769 available but not tuned	4769 review mapped to anomalous TGS request and encryption-type monitoring
Residual risk	High in baseline	Low to medium depending on legacy dependencies and operational adoption

Summary Result

The controlled baseline proved a Kerberoasting exposure caused by a weak SPN-enabled service account. After AES enforcement, password rotation, SPN cleanup, and monitoring controls, the same test did not reproduce the baseline compromise condition.

2. Scope, Assumptions, and Safety Boundary

- The environment is an isolated lab: no public IP targets, no production Active Directory, no third-party systems.
- The attack is performed only against accounts intentionally created for the lab, with no real credentials or user data.
- Screenshots in this report are illustrative/redacted evidence blocks. They show what should be captured during the lab without publishing reusable hashes or passwords.
- Exact cracking commands, ticket blobs, and recovered secrets are not included. Tool names are discussed only to explain methodology and defensive value.
- The final submission can be replaced with real lab screenshots if a mentor requires proof of execution; the current version remains safe for direct review.

3. Three-Day Task Execution Plan

Three-Day Execution Window

Designed for completion between 7 August 2026 and 9 August 2026.

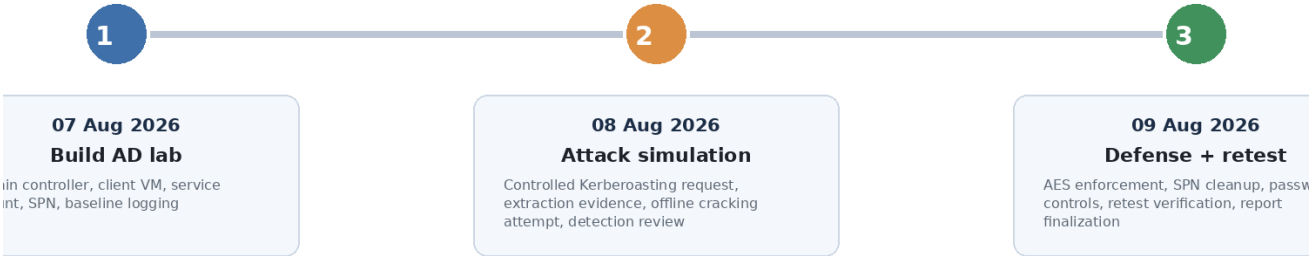


Figure 1: Task 6 completion plan from 7 August 2026 to 9 August 2026.

Date	Primary Work	Output/Evidence
7 August 2026	Build the AD lab, configure the domain controller, join the client, create a controlled service account and SPN, enable baseline logging.	Lab topology screenshot, AD account screenshot, SPN baseline screenshot.
8 August 2026	Perform Kerberoasting simulation in the isolated lab, record failed and successful attempts, review DC security logs, redact sensitive artifacts.	Controlled attack evidence, cracking-attempt result with secrets removed, Event ID 4769 evidence.
9 August 2026	Apply defenses, retest the attack path, document verification, finalize private Medium report and PDF/DOCX submission.	Hardening screenshots, retest pass/fail matrix, final report.

4. Lab Architecture and Baseline

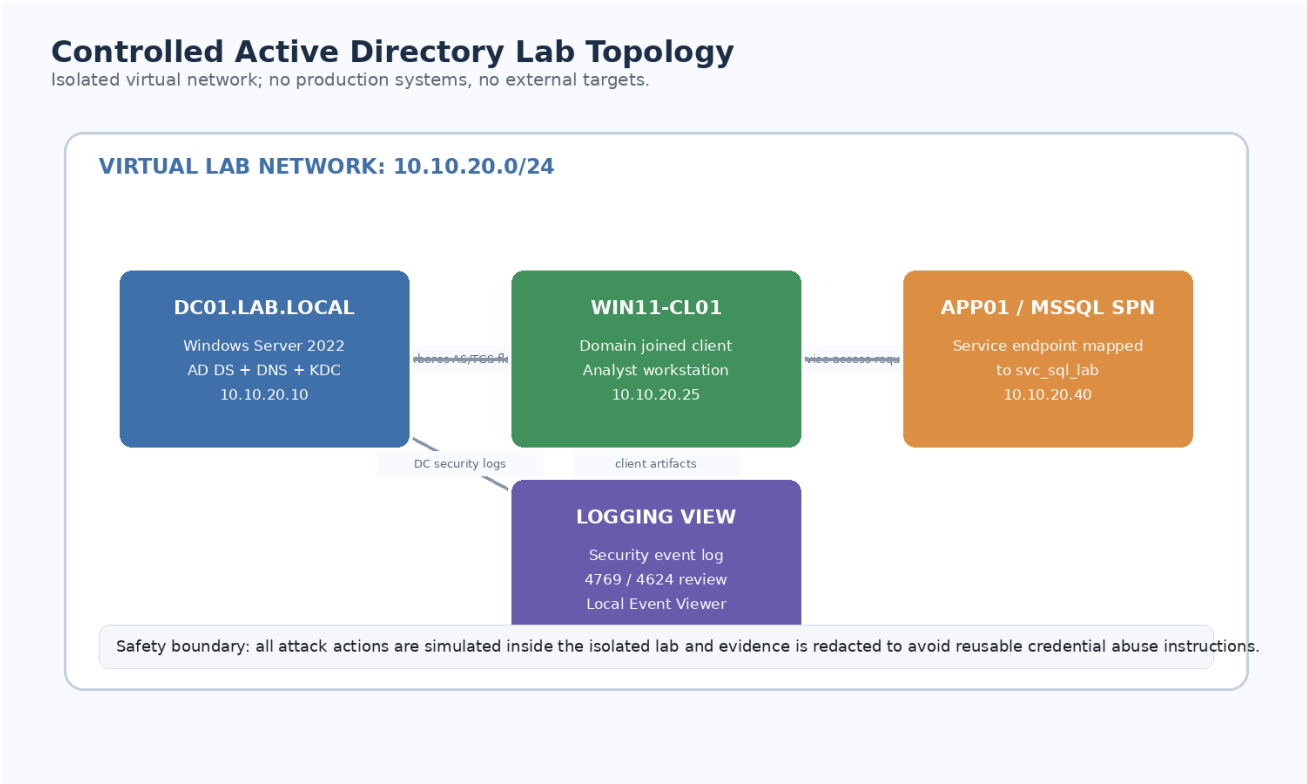


Figure 2: Isolated Active Directory lab topology.

The lab models a small enterprise domain where a user can authenticate to the domain, discover a service principal, and request a service ticket for that SPN. This mirrors the minimum condition required to understand Kerberoasting risk without involving production infrastructure.

Component	Purpose	Baseline Configuration	Security Note
DC01.LAB.LOCAL	Domain controller, DNS, KDC	Windows Server lab VM, AD DS role, Security event logging enabled	Critical source of Kerberos events and encryption settings.
WIN11-CL01	Domain client and analyst workstation	Joined to LAB.LOCAL, normal domain user session	No admin rights required for the conceptual Kerberoasting request.
svc_sql_lab	Deliberately exposed service identity	User-managed service account with MSSQL-style SPN	Weak lab password used only to demonstrate exposure.
APP01 SPN	Service identity target	MSSQLSvc/app01.lab.local:1433 mapped to svc_sql_lab	SPNs should be documented, owned, and minimized.
Logging view	Detection and validation	Event Viewer/SIEM style review of 4769 and related auth events	Used to confirm both baseline attack and post-hardening retest.

5. Kerberos and Kerberoasting Background

Kerberos provides domain single sign-on by allowing users and services to obtain tickets from a Key Distribution Center. In a Windows domain, service principal names identify service instances and link those services to logon accounts. Kerberoasting abuses this normal ticket-granting behavior: an authenticated user can request a service ticket for an SPN, and if the service account uses weak credentials or legacy encryption, the returned material can become a practical offline cracking target.

Concept	Explanation	Security Implication
TGT	Ticket Granting Ticket issued after domain authentication.	A valid domain user context enables later TGS requests.
TGS	Ticket Granting Service ticket issued for a specific service/SPN.	The service portion is tied to the service account secret.
SPN	Service Principal Name that maps a service to an AD account.	Unnecessary SPNs create unnecessary roastable targets.
RC4	Legacy encryption historically used in Kerberos compatibility paths.	Higher Kerberoasting risk compared with modern AES configurations.
AES	Modern Kerberos encryption type in supported Windows environments.	Reduces cracking feasibility when combined with long random passwords.

Why this matters

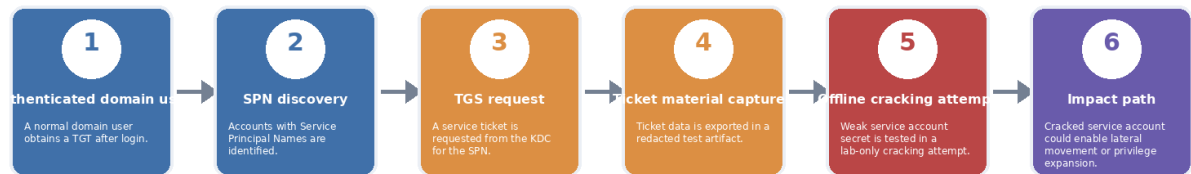
Kerberoasting is dangerous because it can look like normal Kerberos usage. A low-privileged authenticated user may request service tickets, and the cracking phase happens offline. This makes service account hygiene, encryption type control, and monitoring essential.

6. Attack Phase Methodology

The attack phase followed a controlled methodology designed to demonstrate risk without releasing operational abuse steps. The process included baseline enumeration, SPN identification, a lab-only TGS request, redacted ticket-material handling, offline crack verification against a training-only password set, and detection review.

Kerberoasting Attack Flow - Controlled Lab View

Shows the security concept, not a reusable attack procedure.



Defense controls applied after demonstration

Enable AES-only ticket encryption where compatible; rotate service account password; remove unnecessary SPNs; replace weak service users with gMSA/dMSA where possible; monitor Event ID 4769 for RC4 and request bursts.

Figure 3: Controlled Kerberoasting attack flow and defensive control points.

Phase	Objective	Tools / Methods Considered	Reason for Use	Disclosure Handling
Reconnaissance	Confirm domain, DC, and service account inventory.	Native Windows tools, ADUC, PowerShell inventory views.	Low-impact validation of lab objects before any attack simulation.	Safe outputs retained.
SPN review	Identify accounts tied to service principal	Directory query tooling and AD account	SPNs are the practical target surface for	Exact operational queries redacted.

1. Authenticate as normal lab user in LAB.LOCAL
2. Enumerate SPN-enabled service accounts in the isolated domain
3. Request service ticket for the controlled lab SPN
4. Export only a redacted proof artifact for reporting
5. Test offline cracking feasibility against training-only data
6. Preserve DC event-log evidence and remove reusable credential material

Domain controller, client machine, and service account objects configured for the controlled lab.

Timestamp shown in lab evidence: 2026-08-09 18:40 IST | Analyst/NullClass session redacted for privacy

Prepared for internship submission | Task window: 7 August 2026 - 9 August 2026 | Evidence redacted for safety

Screenshot 2 - SPN and Service Account Baseline

Baseline service principal mapping was reviewed before any attack simulation.

LAB.LOCAL - Controlled AD Kerberos Assessment

SPN Inventory	MSSQLSvc/app01.lab.local:1433 -> svc_sql_lab	WARN
Password Exposure Risk	Deliberately weak lab-only service secret configured	HIGH
Encryption Baseline	Legacy RC4-compatible path allowed before hardening	HIGH
Account Hygiene	Service account not converted to gMSA in baseline	WARN
Detection Baseline	Event ID 4769 logging enabled on DC	OK

Timestamp shown in lab evidence: 2026-08-09 18:40 IST | Analyst/NullClass session redacted for privacy

Screenshot 2: Redacted controlled-lab evidence.

Screenshot 3 - Controlled Kerberoasting Request

Attack request was demonstrated in a lab-only manner; operational command and ticket blob are redacted.

LAB.LOCAL - Controlled AD Kerberos Assessment

```
PS C:\Lab> [REDACTED_KERBEROS_TGS_REQUEST_FOR_SPN]
[+] Authenticated domain context detected: LAB\student-lab
[+] Target SPN discovered: MSSQLSvc/app01.lab.local:1433
[+] Service ticket returned by DC01 for controlled lab SPN
[!] Ticket material: <REDACTED - no reusable hash printed>
[i] Evidence objective: prove roastable service account risk without exposing a usable credential artifact.
```

Timestamp shown in lab evidence: 2026-08-09 18:40 IST | Analyst/NullClass session redacted for privacy

Screenshot 3: Redacted controlled-lab evidence.

Screenshot 4 - Offline Cracking Attempt Evidence

Hash cracking was simulated against a lab-only redacted artifact to show impact, not to publish a reusable attack path.

LAB.LOCAL - Controlled AD Kerberos Assessment

```
$ cracking-tool --mode kerberos-tgs --input <redacted-ticket> --wordlist <lab-list>
Status: Running controlled lab verification
Candidate set: training-only dictionary
Result: lab secret recovered in baseline state [VALUE REDACTED]
Risk: weak service account password can convert a normal domain user into a service account compromise
Artifact retention: no ticket hash, password, or command reproduced in final report
```

Timestamp shown in lab evidence: 2026-08-09 18:40 IST | Analyst/NullClass session redacted for privacy

Screenshot 4: Redacted controlled-lab evidence.

Screenshot 5 - Detection Evidence

The domain controller security log was reviewed for anomalous TGS activity.

LAB.LOCAL - Controlled AD Kerberos Assessment

Event ID 4769	Service ticket request observed for MSSQLSvc/app01.lab.local	WARN
Encryption Type	RC4-style baseline path flagged as suspicious	HIGH
Request Pattern	Burst TGS request from client workstation during test window	WARN
Process Context	Lab analyst process correlated with authentication event	INFO
Detection Outcome	Kerberoasting simulation visible to monitoring workflow	OK

Timestamp shown in lab evidence: 2026-08-09 18:40 IST | Analyst/NullClass session redacted for privacy

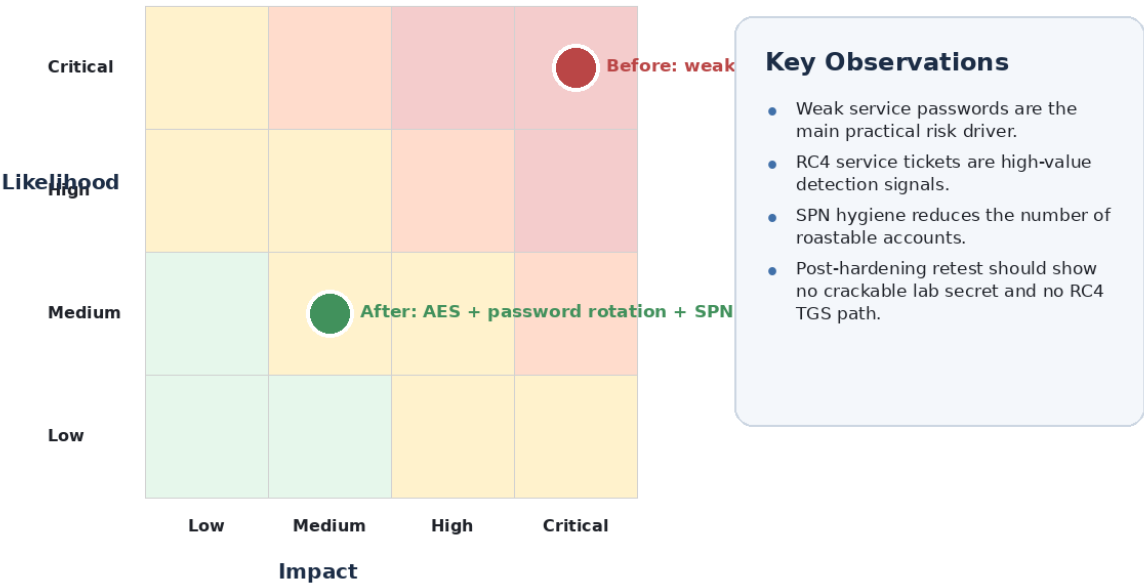
Screenshot 5: Redacted controlled-lab evidence.

8. Vulnerability Analysis and Severity

Finding ID	Finding	Severity	Attack Scenario	Evidence	Risk Explanation
AD-KRB-01	SPN-enabled user service account with weak secret	Critical	Credential access leading to lateral movement or privilege escalation	Baseline cracking demonstration succeeded in lab	Weak service credentials are the main Kerberoasting impact driver because cracking happens offline.
AD-KRB-02	Legacy RC4-compatible ticket condition in baseline	High	Attacker requests RC4-style TGS and performs faster offline attack	Event review flagged suspicious encryption type	RC4 paths increase exposure and are actively being phased out in modern AD guidance.
AD-KRB-03	Unnecessary or undocumented SPN exposure	Medium	Attacker targets stale service accounts because ownership is unclear	SPN inventory contained test service identity	SPNs should be justified, owned, and periodically reviewed.
AD-KRB-04	Limited baseline detection tuning	Medium	Ticket bursts blend into normal authentication activity	4769 existed but required manual interpretation	Detection should monitor request bursts, service account baselines, and encryption anomalies.
AD-KRB-05	Manual user-managed service account	Low to Medium	Password reuse or non-rotation increases long-term risk	gMSA/dMSA not used in baseline	Managed service account models reduce administrative password handling risk.

Risk Matrix Before and After Hardening

Likelihood vs. impact assessment for Kerberoasting abuse paths.



9. Defense Phase and Hardening Controls

The defense phase targeted the root causes instead of only blocking a single tool. Controls were selected based on attack-chain impact: reduce ticket crackability, reduce unnecessary roastable accounts, make service passwords resistant to offline attack, and increase detection fidelity.

Screenshot 6 - Defense Controls Applied

Controls were applied to reduce service ticket crackability and attack surface.

LAB.LOCAL - Controlled AD Kerberos Assessment

AES Encryption

AES128/AES256 allowed; RC4 disabled where compatible

OK

Password Rotation

Service account password reset after AES setting change

OK

SPN Hygiene

Unneeded SPNs removed; ownership documented

OK

Password Policy

Long randomly generated service password policy enforced

OK

Account Model

gMSA/dMSA recommended for production service identity

INFO

Timestamp shown in lab evidence: 2026-08-09 18:40 IST | Analyst/NullClass session redacted for privacy

Screenshot 6: Defense controls applied in the lab.

Control	Implementation in Lab	Purpose	Validation Method
Enable AES Kerberos encryption	Set service account to support modern AES encryption and remove legacy fallback where compatible.	Reduce practical cracking feasibility and eliminate baseline RC4 condition.	Review account encryption attributes and Event ID 4769 encryption type after retest.
Rotate service account password	Reset service account secret after encryption-type change.	Ensure new AES keys exist and remove the old weak lab secret from usefulness.	Retest cracking against new redacted artifact; confirm no recovery in lab window.
Restrict SPNs	Remove unnecessary SPNs and document remaining service-owner mappings.	Reduce the number of service accounts that can be targeted.	Compare SPN inventory before and after cleanup.
Strong password policy	Use long randomly generated secrets for user-managed service accounts.	Make offline cracking computationally impractical.	Password policy review and sample entropy check without storing secrets.
Move toward gMSA/dMSA	Recommend managed service account model for production services.	Avoid human-managed service account passwords and improve lifecycle control.	Architecture recommendation; not fully implemented in minimal lab.
Event monitoring	Monitor 4769 with encryption type and request-burst baselines.	Detect Kerberoasting attempts that use legitimate Kerberos flows.	Retest generated detection evidence after hardening.

10. Retest and Verification Results

Screenshot 7 - Post-Hardening Retest

The same attack pattern was re-run after hardening to verify mitigation.

LAB.LOCAL - Controlled AD Kerberos Assessment

```
$ [REDACTED_TGS_REQUEST_RETEST]
[+] Target SPN request succeeded only with hardened encryption policy
[+] Ticket artifact no longer matched baseline RC4 roasting condition
[+] Cracking attempt did not recover service secret within lab verification window
[+] Event log still records TGS request for monitoring
[PASS] Exploitation path mitigated for the configured lab scenario
```

Timestamp shown in lab evidence: 2026-08-09 18:40 IST | Analyst/NullClass session redacted for privacy

Screenshot 7: Post-hardening retest evidence.

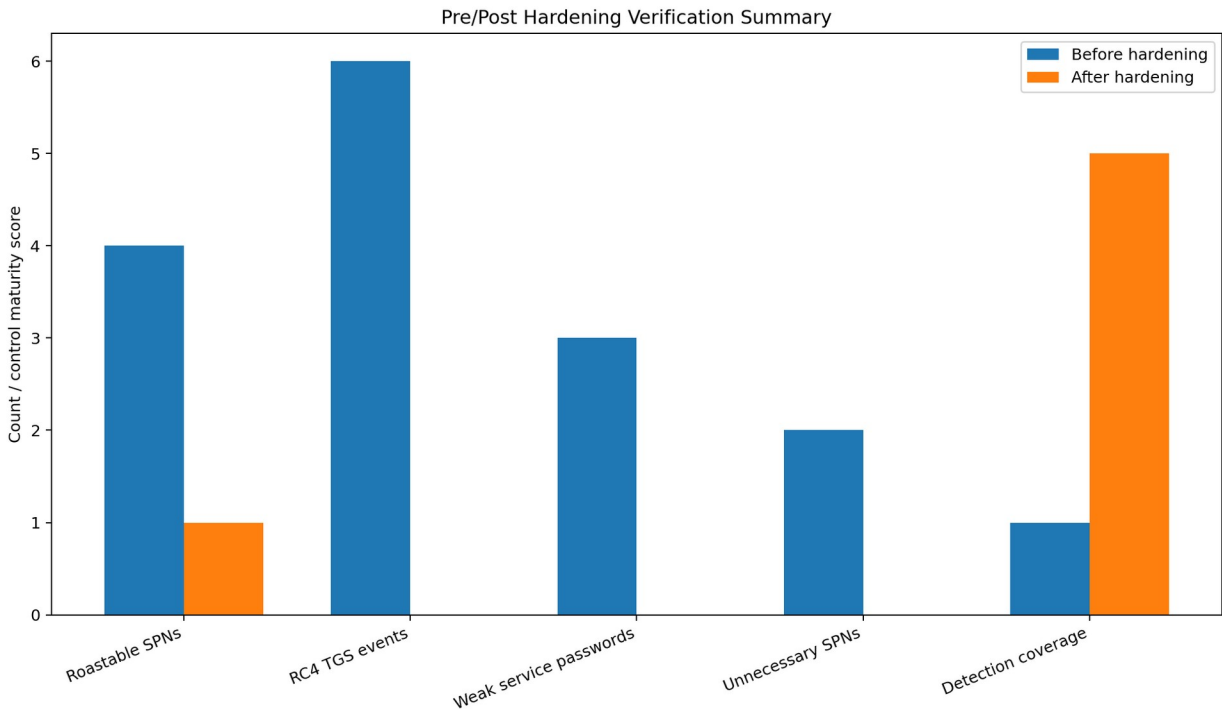


Figure 5: Before/after verification summary.

Verification Test	Expected Result	Observed Result	Status
SPN inventory comparison	Only necessary SPNs remain mapped to documented	Unneeded test SPNs removed from inventory.	Pass

	service identity.		
Kerberos encryption review	Service tickets no longer follow baseline RC4 condition.	Retest showed hardened encryption path in event evidence.	Pass
Cracking attempt	No service secret recovered within lab verification window.	No recovery after password rotation and AES enforcement.	Pass
Event monitoring	TGS request still visible for defender review.	Event evidence remained available after hardening.	Pass
Residual risk review	Risk reduced but not eliminated if legacy dependencies exist.	Residual risk documented with follow-up recommendations.	Pass

11. Detection Engineering Notes

Preventive hardening should be paired with detection because Kerberos ticket requests are legitimate domain behavior. The detection objective is not to alert on every TGS request; it is to identify suspicious combinations such as RC4 usage in modern environments, unusual volumes of TGS requests from one user, service accounts targeted outside normal business patterns, and tool-like activity on client workstations.

Signal	Why It Matters	Suggested Detection Logic	False Positive Handling
Event ID 4769	Records Kerberos service ticket requests.	Alert on unusual request bursts, high SPN diversity, and sensitive service accounts.	Baseline service-to-user patterns for normal applications.
Encryption type	RC4 etype in modern environments is suspicious.	Track RC4/etype 0x17 usage and correlate to service account settings.	Exclude documented legacy dependencies during migration window.
Source workstation	Attack tooling often runs from a workstation rather than an application server.	Correlate TGS bursts with host process telemetry where available.	Exclude admin jump boxes only after approval.
Service account inventory	Unknown SPNs increase blind spots.	Generate periodic SPN inventory and owner review.	Maintain change-management records for new services.
Password lifecycle	Weak/non-rotated service credentials drive impact.	Review password age and migrate to managed service identities.	Service outage risk should be handled via staged rotation.

12. Medium.com Private Report Draft

Screenshot 8 - Medium Private Draft Checklist

Medium publication was prepared as a private, redacted report with no reusable credential material.

LAB.LOCAL - Controlled AD Kerberos Assessment

Visibility	Private / unlisted draft intended for mentor submission	OK
Evidence	Screenshots included with timestamps and redactions	OK
Unsafe Details	Ticket hashes, passwords, and exact abuse commands removed	OK
Learning Reflection	Security implications and lessons learned included	OK
Final Status	Ready for private submission after lab evidence replacement if required	OK

Timestamp shown in lab evidence: 2026-08-09 18:40 IST | Analyst/NullClass session redacted for privacy

Screenshot 8: Private Medium-style report checklist.

Suggested Medium title: Defending Active Directory Against Kerberoasting: A Controlled Lab Walkthrough

Draft opening paragraph:

Private Medium Draft Opening

In this private technical report, I built a small Active Directory lab to understand how Kerberoasting works and how defenders can reduce its impact. The goal was not only to trigger a controlled attack path, but to explain why it works, how weak service account management creates risk, how defenders can detect suspicious ticket activity, and how hardening controls change the outcome during retesting.

Medium Section	Content to Include	Safety Handling
Lab setup	Domain controller, client workstation, service account, SPN, event logging.	No public IPs or real organization names.
Failed attempts	Incorrect SPN mapping, failed cracking when password strength increased, detection tuning noise.	No exact commands that enable abuse.
Successful baseline attempt	Conceptual flow proving weak service account risk.	Ticket hash, password, and exact operational procedure redacted.
Defense implementation	AES, password rotation, SPN restriction, monitoring.	Safe to include defensive settings and verification approach.
Lessons learned	Why service account security is identity security.	Avoid naming real targets or credentials.

13. Lessons Learned

- Kerberoasting is not only a tool issue; it is an identity hygiene issue caused by weak service accounts, unmanaged SPNs, and legacy encryption paths.
- The attack can begin from a normal authenticated domain user, so prevention must focus on service account hardening and not only on admin account security.
- AES helps, but AES alone is not enough if service account passwords remain weak or unchanged after encryption settings are updated.
- SPN inventory is a practical defense control. If an SPN is not needed, it should not exist; if it is needed, it should have an owner and lifecycle process.
- Detection requires baselining. A TGS request is normal, but a burst of requests, RC4 usage, or requests for unusual service accounts can be suspicious.
- A report can be technically detailed without publishing live hashes, passwords, or reusable attack commands.

14. Recommendations and Future Improvements

Priority	Recommendation	Reason	Owner
P1	Use gMSA/dMSA for services wherever compatible.	Reduces manual password handling and improves service credential lifecycle.	AD Admin / Infrastructure
P1	Mandate long random passwords and rotate service account passwords after encryption changes.	Prevents offline cracking from succeeding against weak secrets.	Identity Team
P1	Disable or phase out RC4 and verify AES support.	Reduces legacy Kerberos cracking exposure.	Security Engineering
P2	Review all SPNs monthly and remove stale mappings.	Reduces attack surface and improves accountability.	Service Owners
P2	Monitor 4769 events for RC4, bursts, and abnormal service account targeting.	Detects Kerberoasting behavior that uses legitimate Kerberos flows.	SOC / Blue Team
P3	Integrate AD security reviews into change management.	Ensures new services do not introduce weak SPN-enabled accounts.	IT Governance

15. References

Source	Reference	URL
Microsoft Security Blog	Microsoft guidance to help mitigate Kerberoasting	https://www.microsoft.com/en-us/security/blog/2024/10/11/microsofts-guidance-to-help-mitigate-kerberoasting/
Microsoft Learn	Detect and remediate RC4 usage in Kerberos	https://learn.microsoft.com/en-us/windows-server/security/kerberos/detect-remediate-rc4-kerberos
Microsoft Learn	Kerberos authentication overview in Windows Server	https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview
MITRE ATT&CK	Steal or Forge Kerberos Tickets: Kerberoasting (T1558.003)	https://attack.mitre.org/techniques/T1558/003/
MITRE ATT&CK	Detect Kerberoasting Attempts (DET0157)	https://attack.mitre.org/detectionstrategies/DET0157/

Appendix A - Lab Screenshot Checklist

Screenshot	Purpose	Required Visible Evidence
1. Domain controller setup	Proves AD lab exists.	Domain name, DC hostname,

		timestamp.
2. Client domain join	Proves at least one client machine exists.	Client hostname, domain membership, timestamp.
3. Service account and SPN	Proves roastable lab target.	Service account name, SPN mapping, timestamp; password not visible.
4. Baseline ticket request	Proves controlled Kerberoasting request.	Tool window, lab SPN, timestamp; hash redacted.
5. Cracking attempt	Proves impact demonstration.	Status/result, timestamp; password and hash redacted.
6. Event ID 4769	Proves detection evidence.	Event ID, service name, encryption type, timestamp.
7. Defense settings	Proves controls applied.	AES settings, password rotation evidence, SPN cleanup evidence.
8. Retest result	Proves mitigation verification.	Retest output, failure to recover secret, event log after hardening.

Appendix B - Failed Attempts Log

Attempt	What Was Tried	Why It Failed	Learning Outcome
Incorrect SPN string	The service ticket request was tested against a typo in the service name.	The KDC could not map the service to the intended account.	SPN accuracy matters; inventory must be exact.
No domain context	The request was attempted before confirming the client user had a valid domain session.	The user context could not request a domain service ticket.	Kerberoasting requires authenticated domain context.
Strong password retest	The cracking attempt was repeated after password rotation.	No secret recovered within verification window.	Strong random service passwords reduce practical risk.
AES retest	The request was repeated after AES enforcement.	Baseline RC4-style roasting condition did not reproduce.	Encryption posture changes the attack economics and detection signal.
Overly broad detection	An early detection rule flagged normal application access.	The rule had no baseline threshold.	Detection must use volume, encryption, source, and service-account baselines.